

src/app/securityInsights.ts

Kind: added · Baseline: 9aadd5eb5604 · Target: NovaDiff · Generated: 2026-05-26T19:33:16.839Z

Overview

A new file `src/app/securityInsights.ts` has been added. It introduces utilities for working with `RiskSignal` objects: sorting, merging, and grouping into semantic categories.

Key changes

- **Import** – line 1: `import type { RiskSignal } from "./types";` brings the `RiskSignal` type into scope.
- **sortRiskSignals** – lines 9-16: sorts an array of `RiskSignal` by severity (`high` → `low`) using a rank map, then by category and title.
- **mergeRiskSignals** – lines 18-30: combines two arrays (`heuristic` , `advisory`), removes duplicates by `id` (keeping the last occurrence), and returns the result sorted via `sortRiskSignals` .
- **SecurityInsightGroups** – lines 32-38: interface defining five groups (`vulnerabilities` , `dependenciesConfig` , `memoryLeaks` , `functionCompleteness` , `others`).
- **groupSecuritySignals** – lines 40-79: sorts the input, then assigns each signal to a group based on case-insensitive string checks on `category` or `source` . Signals with `source === "advisory"` or categories containing `"cve"` or `"vulner"` go to `vulnerabilities` ; `"memory"` → `memoryLeaks` ; `"completeness"` or `"coverage-gap"` → `functionCompleteness` ; `"dependency"` , `"config"` , `"auth"` , or `"build"` → `dependenciesConfig` ; all others go to `others` .

Impact

- Provides deterministic ordering and de-duplication of `RiskSignal` objects.
- Centralizes signal handling logic in a single module, simplifying future extensions.
- Sorting uses `Array.sort` , which is $O(n \log n)$; grouping is linear after sorting.

Risks & follow-ups

- **Regression** – ensure existing consumers of `RiskSignal` data continue to work when the new grouping logic is applied.
- **Edge cases** – `mergeRiskSignals` skips items lacking an `id` ; `sortRiskSignals` defaults unknown severities to rank 3.
- **Category heuristics** – the string-matching logic is case-insensitive but may misclassify custom categories; review thresholds if new categories appear.
- **Testing** – add unit tests covering sorting order, merge deduplication, and group assignment to guard against future changes.